

# Orientação ao aluno para o Plano de Governança de TI

Projeto Integrador Interdisciplinar IV | Quarto semestre

## Finalidade

Este documento explica o que a equipe deverá planejar, aplicar e comprovar em relação à Governança de TI no Projeto Integrador Interdisciplinar IV. O objetivo é demonstrar que a solução tecnológica está alinhada a uma necessidade, possui responsáveis, trata riscos, segue controles mínimos e mede resultados. A governança deverá orientar decisões durante o projeto, e não ser produzida apenas depois que o sistema estiver pronto.

## Escopo do Projeto Integrador IV

No quarto semestre, o projeto deve integrar cibersegurança, aplicações mobile, aplicações web, gestão de projetos, empreendedorismo e inovação, além da unidade eletiva definida para a turma. O Plano de Governança deverá apoiar as decisões dessa solução integrada: requisitos de segurança, responsabilidades, riscos, critérios de aceite, continuidade, conformidade e valor do modelo de negócio.

|                            |                                                                                                  |
|----------------------------|--------------------------------------------------------------------------------------------------|
| <b>ENTREGA OBRIGATÓRIA</b> | Plano de Governança de TI em formato PDF dentro do repositório do projeto.                       |
| <b>NOME RECOMENDADO</b>    | docs/plano-governanca-ti.pdf                                                                     |
| <b>VERSÃO EDITÁVEL</b>     | Deve ser mantida junto ao projeto para permitir atualização e geração do PDF.                    |
| <b>EVIDÊNCIAS</b>          | Código, configurações, histórico Git, pipeline, testes, logs e documentos coerentes com o plano. |

## O que significa aplicar governança

Aplicar governança significa definir como a TI será direcionada e controlada para entregar valor. A equipe deverá responder, com evidências, a cinco perguntas:

- 1 Qual necessidade do usuário ou do processo industrial será atendida e qual valor é esperado?
- 2 Quem decide prioridades, aprova mudanças, aceita riscos e valida a entrega?
- 3 Quais pessoas, tecnologias, dados, serviços, tempo e custos são necessários?
- 4 Quais riscos e regras precisam ser tratados?
- 5 Quais indicadores mostrarão se a solução e o processo de desenvolvimento tiveram bom desempenho?

*Governança não é somente documentação. A avaliação considerará a correspondência entre o plano e aquilo que foi realmente configurado, executado e registrado no repositório.*

# 1 Entrega obrigatória no repositório

No Projeto Integrador IV, o Plano de Governança de TI deverá estar presente no repositório utilizado na avaliação e deverá ser entregue obrigatoriamente em PDF. O caminho recomendado é docs/plano-governanca-ti.pdf. O arquivo precisa abrir corretamente, estar legível e corresponder à versão final do projeto.

## Requisitos da entrega

- O PDF deve estar versionado no mesmo repositório do código-fonte.
- A equipe deve manter também a fonte editável do documento, por exemplo Markdown, DOCX ou arquivo equivalente.
- O histórico do repositório deve mostrar atualizações do plano ao longo do desenvolvimento.
- O README deve possuir um link para o PDF e indicar onde estão as principais evidências de governança.
- O conteúdo deve refletir o sistema entregue; modelos genéricos ou itens que não foram aplicados não serão considerados evidência.
- Dados sigilosos, senhas, tokens e credenciais não podem constar no PDF nem no repositório.

## Estrutura recomendada do repositório

| Local                             | Finalidade                                                            |
|-----------------------------------|-----------------------------------------------------------------------|
| README.md                         | Visão do projeto, execução, integrantes e índice das evidências.      |
| docs/plano-governanca-ti.pdf      | Entrega oficial e obrigatória do plano.                               |
| docs/plano-governanca-ti.md       | Fonte editável recomendada do plano.                                  |
| docs/decisoões/                   | Registros curtos das decisões relevantes de arquitetura e governança. |
| docs/riscos.md                    | Registro de riscos, quando mantido separadamente.                     |
| .github/workflows/ ou equivalente | Pipeline de integração e entrega contínua.                            |
| src/ e tests/                     | Código da solução e testes automatizados.                             |
| Dockerfile e compose.yaml         | Ambiente reproduzível, quando aplicável.                              |
| .env.example                      | Nomes das variáveis necessárias, sem valores secretos.                |

## Condição de recebimento

A ausência do PDF obrigatório impede a pontuação dos critérios diretamente dependentes do Plano de Governança. Arquivo fora do repositório, link externo isolado ou documento ilegível será tratado como entrega não conforme até o prazo definido pelo docente.

## 2 Conteúdo obrigatório do Plano de Governança

| Seção                                 | Conteúdo mínimo                                                                                      |
|---------------------------------------|------------------------------------------------------------------------------------------------------|
| 1. Identificação e controle da versão | Nome do projeto, equipe, data, versão e histórico resumido de alterações.                            |
| 2. Contexto, problema e valor         | Necessidade atendida, usuários, resultado esperado, escopo e itens fora do escopo.                   |
| 3. Partes interessadas                | Quem é afetado, seus interesses, influência e forma de comunicação.                                  |
| 4. Papéis e decisões                  | Matriz RACI ou equivalente; responsáveis por priorização, aprovação, operação e aceite de riscos.    |
| 5. Políticas e controles              | Regras aplicáveis a acesso, credenciais, mudanças, testes, versões, dados, incidentes e recuperação. |
| 6. Riscos                             | Risco, causa, impacto, probabilidade, resposta, responsável, situação e risco residual.              |
| 7. Serviço de TI                      | Descrição do serviço, usuários, dependências, disponibilidade esperada, suporte e limitações.        |
| 8. Indicadores                        | Indicadores de valor, qualidade técnica e processo de entrega, com fórmula, fonte, meta e resultado. |
| 9. Continuidade e recuperação         | Backup quando aplicável, rollback, recuperação e responsáveis.                                       |
| 10. Conformidade e ética              | Privacidade, origem e necessidade dos dados, licenças, acessibilidade e uso responsável.             |
| 11. Evidências de aplicação           | Links ou caminhos do repositório que comprovem cada controle declarado.                              |
| 12. Avaliação final                   | Valor entregue, metas alcançadas, incidentes, riscos residuais e melhorias propostas.                |

### Políticas mínimas esperadas

- Nenhuma credencial ou segredo será versionado; valores sensíveis serão fornecidos por mecanismo seguro.
- Mudanças no código passarão por revisão e por verificações automáticas antes da integração.
- Versões implantadas serão identificáveis e terão procedimento de retorno à versão anterior.
- O acesso seguirá a necessidade da função e o princípio do menor privilégio, quando aplicável.
- Dados terão origem, finalidade, necessidade de uso e período de retenção descritos.
- Falhas e incidentes relevantes serão registrados, classificados e acompanhados.

### 3 Instruções de execução e evidências cobradas

| Dimensão             | Exemplos de evidência                                                                                                              |
|----------------------|------------------------------------------------------------------------------------------------------------------------------------|
| Alinhamento e valor  | Objetivo mensurável, requisitos priorizados, indicador de negócio e aceite do usuário.                                             |
| Responsabilidade     | RACI coerente, responsáveis no repositório, revisões e registro de decisões.                                                       |
| Gestão de mudanças   | Issues, branches, pull requests, commits rastreáveis, revisão e pipeline.                                                          |
| Qualidade            | Testes automatizados, relatório de execução e critérios que bloqueiam integração inadequada.                                       |
| Segurança            | Ausência de segredos, variáveis protegidas, validação de entradas, controle de acesso e análise de dependências, conforme o risco. |
| Dados e conformidade | Fonte e finalidade dos dados, minimização, proteção e licenças identificadas.                                                      |
| Continuidade         | Imagem ou versão identificável, backup quando necessário, rollback descrito e teste de recuperação.                                |
| Operação             | Logs úteis, tratamento de erros, métricas, alertas e procedimento de suporte.                                                      |
| Desempenho           | Resultados dos indicadores comparados com metas e interpretação dos desvios.                                                       |

#### Rastreabilidade obrigatória

Para cada política ou controle declarado, o plano deverá informar onde está a evidência. Exemplos: arquivo do pipeline, teste, configuração, pull request, issue, log, painel, relatório ou procedimento. Quando não for possível fornecer um link permanente, informe o caminho e explique como a evidência será demonstrada.

| ID     | Controle                           | Evidência                         | Como comprovar                                      |
|--------|------------------------------------|-----------------------------------|-----------------------------------------------------|
| GOV-01 | Mudança deve passar por testes     | .github/workflows/ci.yml          | Pipeline executa testes e bloqueia falhas           |
| GOV-02 | Segredos não podem ser versionados | .gitignore e .env.example         | Variáveis documentadas sem valores reais            |
| GOV-03 | Versão deve permitir rollback      | tags, releases e docs/rollback.md | Versão anterior identificada e procedimento testado |

## 4 Como executar e comprovar a governança

Sim. Parte da aplicação da governança do Projeto Integrador IV pode ser checada diretamente no código, nas configurações e no histórico do repositório. Essa checagem comprova a implementação de controles técnicos. Entretanto, ela não prova sozinha alinhamento estratégico, valor para o negócio, qualidade das decisões ou participação real das partes interessadas. Esses aspectos exigem análise do plano, dos registros e da apresentação.

| Item                            | Tipo de verificação     | Como verificar                                                                           |
|---------------------------------|-------------------------|------------------------------------------------------------------------------------------|
| Presença do PDF                 | Automática              | Validar caminho, extensão, abertura e tamanho mínimo.                                    |
| Estrutura mínima do plano       | Parcialmente automática | Extrair texto e procurar seções, versão, riscos, indicadores e evidências.               |
| Segredos expostos               | Automática              | Scanner de secrets e revisão do histórico Git.                                           |
| Dependências vulneráveis        | Automática              | Auditoria do gerenciador de pacotes e análise de composição.                             |
| Testes e cobertura              | Automática              | Executar testes, coletar resultado e cobertura do fluxo crítico.                         |
| Revisão antes de integrar       | Repositório             | Verificar regras de branch e pull requests; código local isolado não comprova aprovação. |
| Rastreabilidade                 | Parcialmente automática | Relacionar issue, commit, pull request, release e requisito.                             |
| Contêiner e reprodutibilidade   | Automática              | Construir imagem, iniciar serviços e executar health check.                              |
| Qualidade e segurança do código | Automática com revisão  | Lint, análise estática, validação de entrada e padrões inseguros.                        |
| Logs e observabilidade          | Automática com teste    | Gerar evento, confirmar log, métrica e comportamento de alerta.                          |
| Rollback e recuperação          | Teste supervisionado    | Executar procedimento e registrar tempo e resultado.                                     |
| Valor e adequação ao negócio    | Humana                  | Validar objetivo, indicador, demonstração e aceite do usuário.                           |
| Risco e decisão                 | Humana                  | Avaliar qualidade da análise, resposta adotada e risco residual.                         |

### Limite importante

Ter um arquivo chamado política, risco ou governança não significa que a prática foi aplicada. Da mesma forma, possuir testes não comprova que as mudanças foram revisadas. A avaliação cruzará declaração, configuração, histórico e demonstração para verificar consistência.

## 5 Verificações automáticas recomendadas

A equipe deverá incluir no pipeline ou em scripts reproduzíveis as verificações compatíveis com sua tecnologia mobile e web. O conjunto exato pode variar, mas as escolhas e exceções precisam ser justificadas no plano.

| Etapa               | Resultado esperado                                                                         |
|---------------------|--------------------------------------------------------------------------------------------|
| Documentação        | Confirmar que docs/plano-governanca-ti.pdf existe, não está vazio e pode ser lido.         |
| Compilação ou build | Garantir que a aplicação pode ser construída em ambiente limpo.                            |
| Testes              | Executar testes unitários e de integração essenciais; falhas devem interromper o pipeline. |
| Análise estática    | Verificar erros, padrões de qualidade e vulnerabilidades adequadas à linguagem.            |
| Dependências        | Identificar pacotes desatualizados ou vulneráveis e registrar o tratamento.                |
| Segredos            | Detectar tokens, chaves e senhas no conteúdo e, quando possível, no histórico.             |
| Contêiner           | Construir a imagem e analisar vulnerabilidades relevantes.                                 |
| Infraestrutura      | Validar sintaxe e configuração de compose, manifests ou infraestrutura como código.        |
| Execução            | Subir o ambiente, realizar health check e testar o fluxo funcional principal.              |
| Artefatos           | Gerar versão identificável e preservar relatórios de teste e segurança.                    |

### Critério para falhas

Falhas de build, testes essenciais, segredo detectado ou vulnerabilidade crítica sem tratamento devem impedir a entrega automática. Alertas de menor severidade podem ser aceitos temporariamente quando houver justificativa, responsável, prazo e registro do risco residual.

### Revisão manual complementar

- Comparar as políticas declaradas com o pipeline e as configurações reais.
- Selecionar riscos prioritários e localizar as respostas implementadas.
- Verificar se os indicadores possuem dados, fórmula e interpretação.
- Solicitar a demonstração de uma mudança, uma falha e uma recuperação.
- Confirmar que cada integrante compreende as decisões e controles relevantes.

## 6 Critérios de avaliação

| Critério                             | Peso | O que será observado                                                                                |
|--------------------------------------|------|-----------------------------------------------------------------------------------------------------|
| Alinhamento e geração de valor       | 20%  | Problema, usuários, objetivo, escopo, indicador de negócio e resultado estão conectados.            |
| Responsabilidades e decisões         | 15%  | Partes interessadas, RACI, aprovações e decisões são claras, coerentes e utilizadas.                |
| Riscos, conformidade e ética         | 20%  | Riscos relevantes são analisados; controles, privacidade, licenças e riscos residuais são tratados. |
| Controles aplicados no repositório   | 25%  | Mudanças, testes, segurança, versões, recuperação e rastreabilidade possuem evidências reais.       |
| Indicadores e gestão do serviço      | 10%  | Serviço, suporte, metas, fontes, resultados e análise de desempenho estão definidos.                |
| Qualidade do plano e da apresentação | 10%  | PDF completo, legível, atualizado, objetivo e coerente com a demonstração e o repositório.          |

### Níveis de desempenho

| Nível                     | Descrição                                                                                                                 |
|---------------------------|---------------------------------------------------------------------------------------------------------------------------|
| 4 - Plenamente aplicado   | Conteúdo completo e coerente; prática aplicada; evidências rastreáveis; resultados analisados; equipe domina as decisões. |
| 3 - Aplicado              | Requisitos principais atendidos e comprovados; pequenas lacunas não comprometem o controle ou o resultado.                |
| 2 - Parcialmente aplicado | Planejamento existe, mas há lacunas relevantes de execução, evidência, atualização ou coerência.                          |
| 1 - Inicial               | Conteúdo genérico ou incompleto; controles pouco aplicados; evidências frágeis; equipe demonstra compreensão limitada.    |
| 0 - Não evidenciado       | Item ausente, inacessível, incompatível com a entrega ou sem qualquer comprovação.                                        |

### Cálculo

Cada critério receberá um nível de 0 a 4. A pontuação do critério será calculada por:  $(\text{nível obtido} \div 4) \times \text{peso do critério}$ . A soma produzirá uma nota de 0 a 100 para a dimensão de Governança de TI.

### Regras específicas

- Sem o PDF obrigatório no repositório, o critério Qualidade do plano e da apresentação recebe nível 0, e os demais itens sem evidência documental não podem ultrapassar o nível 1.
- Declarar um controle sem evidência limita o respectivo item ao nível 1.
- Evidência existente, mas incompatível com o plano, limita o item ao nível 2.
- Credencial real versionada ou exposição indevida de dados deverá ser corrigida e poderá reduzir a avaliação de riscos e controles, conforme gravidade.
- Cada estudante poderá ser questionado individualmente sobre decisões, riscos e evidências para composição da avaliação individual.

## Matriz de composição da nota

A nota de Governança de TI será composta pela soma ponderada dos seis critérios abaixo. Cada critério receberá um nível de 0 a 4, conforme a tabela de desempenho. A coluna de verificação indica como a evidência principal será obtida; o docente poderá complementar qualquer item com perguntas e demonstração.

| Critério                             | Peso (%) | Verificação principal | Evidência considerada                                                        |
|--------------------------------------|----------|-----------------------|------------------------------------------------------------------------------|
| Alinhamento e geração de valor       | 20       | Manual                | Problema, usuários, objetivo, indicador e resultado.                         |
| Responsabilidades e decisões         | 15       | Manual + repositório  | RACI, registros de decisão, aprovações e participação da equipe.             |
| Riscos, conformidade e ética         | 20       | Manual + automática   | Registro de riscos, privacidade, licenças, secrets e controles de segurança. |
| Controles aplicados no repositório   | 25       | Automática            | Testes, análise, histórico, regras de revisão, versões e recuperação.        |
| Indicadores e gestão do serviço      | 10       | Manual + automática   | Metas, fonte, métricas, logs, suporte e análise dos resultados.              |
| Qualidade do plano e da apresentação | 10       | Manual                | PDF, coerência, clareza, atualização e defesa oral das evidências.           |
| TOTAL                                | 100      |                       | Nota final de Governança de TI                                               |

## Fórmula da nota

Para cada critério: pontuação = (nível obtido ÷ 4) × peso. A nota final é a soma das seis pontuações e varia de 0 a 100. Se a escola utilizar nota de 0 a 10, divida o resultado final por 10. Exemplo: nível 3 no critério de peso 20% gera  $(3 \div 4) \times 20 = 15$  pontos.

## Composição por tipo de verificação

| Tipo                                             | Limite de pontos | O que será analisado                                                                                        |
|--------------------------------------------------|------------------|-------------------------------------------------------------------------------------------------------------|
| Verificação automática ou baseada no repositório | Até 45 pontos    | Testes, segredos, dependências, regras de revisão, rastreabilidade, versão, build e evidências de operação. |
| Verificação manual                               | Até 55 pontos    | Alinhamento, valor, decisões, riscos, ética, qualidade do plano, apresentação e domínio individual.         |

*Os limites acima organizam a origem das evidências e não substituem os pesos dos critérios. Uma evidência automática pode apoiar um critério manual, mas não comprova sozinha valor, decisão ou compreensão da equipe.*



## 7 Checklist antes da entrega

|                          | Verificação                                                                         |
|--------------------------|-------------------------------------------------------------------------------------|
| <input type="checkbox"/> | O arquivo docs/plano-governanca-ti.pdf existe, abre corretamente e está legível.    |
| <input type="checkbox"/> | O README contém link para o PDF e índice das evidências.                            |
| <input type="checkbox"/> | A fonte editável do plano está versionada e o PDF corresponde à versão final.       |
| <input type="checkbox"/> | O problema, o valor esperado, os usuários e o escopo estão claros.                  |
| <input type="checkbox"/> | As partes interessadas e as responsabilidades de decisão estão definidas.           |
| <input type="checkbox"/> | As políticas possuem objetivo, responsável, verificação e evidência.                |
| <input type="checkbox"/> | Os riscos possuem probabilidade, impacto, resposta, responsável e situação atual.   |
| <input type="checkbox"/> | Os indicadores possuem fórmula, fonte, meta, resultado e interpretação.             |
| <input type="checkbox"/> | As evidências citadas existem nos caminhos indicados.                               |
| <input type="checkbox"/> | O pipeline executa build, testes e controles compatíveis com o projeto.             |
| <input type="checkbox"/> | Não há credenciais, tokens, senhas ou dados sigilosos versionados.                  |
| <input type="checkbox"/> | A versão entregue é identificável e existe procedimento de rollback ou recuperação. |
| <input type="checkbox"/> | A equipe consegue demonstrar uma mudança percorrendo o processo definido.           |
| <input type="checkbox"/> | A equipe consegue explicar um risco tratado e um risco residual aceito.             |
| <input type="checkbox"/> | A avaliação final compara metas e resultados e propõe melhorias.                    |

## Orientação final

Comece o Plano de Governança junto com o projeto e atualize-o a cada marco. Use o repositório como fonte de evidências e automatize os controles que puderem ser executados de forma confiável. Na apresentação, mostre a relação entre necessidade, decisão, risco, controle, evidência e resultado. Esse encadeamento será mais importante do que a quantidade de páginas do documento.